

PHISHING CAMPAIGN PRACTICAL SECURITY TIPS

Lessons and defensive guidance from a controlled GoPhish simulation

Prepared by: Omotoso Oluwasegun Akorede

Date: September 20, 2026

Tools used: Gophish (self-hosted, open-source phishing simulation framework)

Purpose

This short guide summarizes practical security tips that can be applied when planning, conducting, or reviewing an authorized phishing-awareness campaign. It is intended for cybersecurity training and controlled environments.

1. Before the Campaign

- Obtain clear authorization and define the scope of the simulation.
- Use only approved test accounts, systems, domains, and infrastructure.
- Avoid collecting real passwords or unnecessary personal information.
- Define what will be measured, such as delivery, opens, clicks, and landing-page visits.
- Prepare a reporting and response process before launching the exercise.

2. Common Phishing Indicators

- Unexpected requests for passwords, payments, verification, or urgent action.
- Suspicious sender addresses, domains, or display names.
- Links whose destination does not match the visible text or expected organization.
- Unusual attachments or unexpected document requests.
- Pressure, urgency, threats, or unusually attractive offers.
- Spelling, grammar, branding, or formatting inconsistencies.

3. What Users Should Do

- Pause before clicking links or opening unexpected attachments.
- Verify unusual requests through a trusted, separate communication channel.
- Hover over links and inspect the destination before opening them.
- Use bookmarks or manually enter known website addresses for sensitive services.
- Report suspected phishing to the organization's designated security or IT team.
- If a suspicious link was clicked, report it promptly rather than hiding the incident.

4. What Security Teams Should Monitor

Area	Useful Observation
Email activity	Delivery, bounce rates, and unusual sending activity.
User interaction	Opens, clicks, and landing-page visits during the exercise.
Reporting	Whether users recognize and report simulated phishing.
Technical controls	Email filtering, authentication controls, and monitoring alerts.
Response	How quickly reported activity is investigated and contained.

5. After the Campaign

- Review campaign metrics and identify patterns rather than focusing only on individual users.
- Document lessons learned, security gaps, and recommended improvements.
- Provide targeted awareness training where appropriate.
- Review email-security controls and reporting procedures.
- Keep campaign data secure and retain only information necessary for the stated purpose.

6. Key Takeaways

- Phishing defense requires both user awareness and technical controls.
- A successful simulation should produce measurable learning and security improvements.
- Campaign results should be interpreted in context and used to improve controls and training.
- Authorization, privacy, and responsible handling of campaign data are essential.

7. Security Findings

The controlled phishing simulation highlighted several security considerations:

- User interaction with phishing content: Simulated phishing emails can successfully attract user attention and encourage interaction with links or landing pages.
- Email trust and verification: Users may rely on sender names, branding, or familiar-looking content without sufficiently verifying the actual sender or destination.
- Phishing indicators: Suspicious links, urgent requests, unusual attachments, and inconsistencies in email content are important indicators that users should recognize.
- Security awareness: Regular awareness training is important because technical security controls alone may not prevent every phishing attempt.

- Incident reporting: Prompt reporting of suspicious emails or accidental interactions can help security teams investigate and respond more quickly.

Recommendations

Based on these observations, the following measures are recommended:

- Conduct regular phishing-awareness and security-awareness training.
- Encourage users to verify suspicious requests before taking action.
- Establish a simple and clearly communicated process for reporting suspected phishing emails.
- Strengthen email filtering and URL protection controls.
- Implement and maintain Multi-Factor Authentication (MFA) for critical accounts.
- Monitor email-security events and investigate unusual activity.
- Conduct periodic, authorized phishing simulations to measure awareness and identify areas for improvement.
- Review campaign results over time to track security-awareness improvements.

Ethical and Security Note

Phishing simulations should be conducted only with appropriate authorization and within legally permitted environments. Do not use these techniques against people, organizations, accounts, or systems without permission.